EL ESLABÓN MÁS DÉBIL:

DISEÑO ÉTICO DE UNA CAMPAÑA DE INGENIERÍA SOCIAL.

Francisco Javier Cruz Juarez - 177622
Maestro: Servando Contreras Lopez
Seguridad Informatica

CONTENIDO

1. Introducción 3
2. Objetivos 3
2.1. Objetivo General 3
2.2. Objetivos Específicos 3
3. Marco Teórico y Fundamentación Técnica 3
3.1. La Ingeniería Social: El Factor Humano 3
3.2. Métricas Críticas de Evaluación (KPIs) 4
3.3. Vectores de Ataque en Ingeniería Social 4
3.4. Enfoques de Entrenamiento y Ética 4
4. Análisis Individual de las 8 Plataformas 5
Ficha Técnica: Hoxhunt 5
1. Descripción General 5
2. Capacidades Técnicas y Diferenciadores 5
3. Métricas y Analítica de Datos 5
4. Enfoque Ético y Privacidad 5
Enlaces y Referencias: 6
Ficha Técnica: Proofpoint (Security Awareness Training) 6
1. Descripción General y Filosofía 6
2. Capacidades Técnicas y Diferenciadores 6
3. Métricas y Analítica de Datos 6
4. Enfoque Ético y Privacidad 7
Enlaces y Referencias: 7
Ficha Técnica: KnowBe4 (Human Risk Management Platform) 8
1. Descripción General y Filosofía 8
2. Capacidades Técnicas y Diferenciadores 8
3. Métricas y Analítica de Datos 8
4. Enfoque Ético y Privacidad 8
Enlaces y Referencias: 9
Ficha Técnica: Cofense (Phishing Detection and Response) 9
1. Descripción General y Filosofía 9
2. Capacidades Técnicas y Diferenciadores 9

3. Métricas y Analítica de Datos 9
4. Enfoque Ético y Privacidad 10
Enlaces y Referencias: 10
Ficha Técnica: Phished (AI-Driven Behavioral Change) 10
1. Descripción General y Filosofía 10
2. Capacidades Técnicas y Diferenciadores 10
3. Métricas y Analítica de Datos 10
4. Enfoque Ético y Privacidad 11
Enlaces y Referencias: 11
Ficha Técnica: NINJIO (Cybersecurity Awareness Training) 11
1. Descripción General y Filosofía 11
2. Capacidades Técnicas y Diferenciadores 11
3. Métricas y Analítica de Datos 11
4. Enfoque Ético y Privacidad 12
Enlaces y Referencias: 12
Ficha Técnica: Mimecast (Awareness Training) 12
1. Descripción General y Filosofía 12
2. Capacidades Técnicas y Diferenciadores 12
3. Métricas y Analítica de Datos 13
4. Enfoque Ético y Privacidad 13
Enlaces y Referencias: 13
Ficha Técnica: Infosec IQ (Security Awareness Training) 13
1. Descripción General y Filosofía 13
2. Capacidades Técnicas y Diferenciadores 13
3. Métricas y Analítica de Datos 14
4. Enfoque Ético y Privacidad 14
Enlaces y Referencias: 14
5. Tabla Técnica Comparativa de Plataformas 15
6. Conclusión 18
7. Referencias 18

1. Introducción

En el panorama actual de la ciberseguridad, los controles técnicos como firewalls y sistemas de detección de intrusiones son insuficientes si no se aborda el factor humano, comúnmente denominado **"el eslabón más débil"**. La ingeniería social se ha consolidado como la técnica preferida por los atacantes, ya que resulta más sencillo manipular la psicología de un usuario que vulnerar un cifrado complejo.

El presente proyecto, **PR02: El eslabón más débil**, se enfoca en el diseño, implementación y evaluación ética de una campaña de simulación de phishing. A través de una investigación comparativa de las plataformas líderes en el mercado —como *KnowBe4, Proofpoint y Hoxhunt*— y el desarrollo de un simulador interactivo (*Phishing Quiz*), se busca medir el nivel de preparación de los usuarios frente a amenazas digitales. Todo el desarrollo se rige bajo principios de **ética digital**, asegurando que la recolección de datos sea formativa y no punitiva, protegiendo en todo momento la integridad y privacidad de los participantes.

2. Objetivos

2.1. Objetivo General

Diseñar, implementar y evaluar de manera ética una simulación educativa de phishing, sustentada en el análisis comparativo de plataformas profesionales del mercado, con el propósito de medir el nivel de reconocimiento de amenazas de ingeniería social en usuarios, interpretar los resultados mediante un sistema de puntuación global y reflexionar sobre la gestión responsable del riesgo humano en seguridad informática.

2.2. Objetivos Específicos

- **Analizar y comparar** 8 plataformas profesionales de simulación de phishing (Hoxhunt, Proofpoint, KnowBe4, Cofense, Phished, NINJIO, Mimecast e Infosec IQ), identificando sus capacidades técnicas, métricas de medición y enfoques éticos.
- **Diseñar e implementar** un simulador interactivo tipo *Phishing Quiz* compuesto por 10 escenarios realistas de ingeniería social, incorporando criterios de evaluación técnica y retroalimentación formativa inmediata.
- **Desarrollar e interpretar** un sistema de *score* global que consolide los resultados de los participantes, permitiendo analizar tendencias de vulnerabilidad y áreas de oportunidad en la concienciación de ciberseguridad.
- **Asegurar el cumplimiento ético** mediante el uso de consentimientos informados y la omisión de captura de credenciales reales, priorizando el aprendizaje sobre la exposición de los usuarios.

3. Marco Teórico y Fundamentación Técnica

3.1. La Ingeniería Social: El Factor Humano

La ingeniería social se define como el conjunto de técnicas psicológicas y de manipulación utilizadas por atacantes para inducir a los usuarios a realizar acciones específicas, como revelar información confidencial o ejecutar software malicioso. En ciberseguridad, el usuario es considerado el **"eslabón**

más débil" de la cadena de defensa, ya que, a diferencia de un sistema informático, el comportamiento humano es impredecible y vulnerable al engaño emocional.

3.2. Métricas Críticas de Evaluación (KPIs)

Para medir la efectividad de una campaña de simulación de phishing, se deben considerar las siguientes métricas técnicas:

- **Click Rate (Tasa de Clics):** Indica el porcentaje de usuarios que interactuaron con el elemento malicioso (enlace o adjunto). Un *Click Rate* alto señala una vulnerabilidad crítica en la cultura de seguridad.
- **Reporting Rate (Tasa de Reporte):** Es la métrica de éxito proactivo. Mide cuántos usuarios utilizaron las herramientas de alerta (como el botón de reporte de phishing) para notificar al equipo de seguridad sobre la amenaza.
- **Resilience Score (Puntuación de Resiliencia):** Un cálculo que cruza la tasa de clics con la de reporte para determinar la capacidad de "supervivencia" de un departamento ante un ataque real.
- **Macro-Conversion:** Ocurre cuando el usuario no solo da clic, sino que completa una acción adicional, como intentar descargar un archivo o llegar a una página de inicio de sesión falsa.

3.3. Vectores de Ataque en Ingeniería Social

Las campañas modernas no se limitan al correo electrónico. Los vectores más comunes incluyen:

1. **Phishing:** Envío de correos electrónicos fraudulentos.
2. **Smishing:** Ataques vía mensajes de texto (SMS) con enlaces maliciosos.
3. **Vishing:** Ingeniería social mediante llamadas telefónicas o voz IP.
4. **Quishing (QR Phishing):** Uso de códigos QR maliciosos que redirigen a sitios de captura de credenciales.

3.4. Enfoques de Entrenamiento y Ética

- **Teachable Moment (Momento de Aprendizaje):** Es el principio educativo que establece que el aprendizaje es más efectivo cuando la retroalimentación ocurre inmediatamente después del error del usuario.
- **Diseño Ético No Punitivo:** Una campaña ética debe evitar el "shaming" (avergonzar al usuario). El objetivo no es castigar el fallo, sino fortalecer la capacidad de detección mediante el refuerzo positivo y la gamificación.
- **Privacidad de Datos:** En una simulación ética, **nunca** se deben capturar contraseñas reales ni datos sensibles. El sistema solo debe registrar si el usuario "habría caído" en el ataque.

4. Análisis Individual de las 8 Plataformas

Este apartado detalla las capacidades diferenciadoras de cada herramienta mencionada en los objetivos.

Ficha Técnica: Hoxhunt

1. Descripción General

Hoxhunt no se define como una herramienta de "simulación de phishing" tradicional, sino como una plataforma de **Transformación del Comportamiento Humano**. Fundada en Helsinki, Finlandia, su enfoque principal es la **gamificación**. A diferencia de otras plataformas que "atrapan" al usuario para castigarlo, Hoxhunt recompensa a los empleados por reportar correos tanto simulados como reales.

2. Capacidades Técnicas y Diferenciadores

- **IA Adaptativa (Adaptive Learning):** El sistema utiliza algoritmos de aprendizaje automático para ajustar la dificultad de los correos.
- **Integración Nativa:** Se instala como un "add-in" en el cliente de correo (Outlook, Gmail). Esto permite que el botón de reporte esté siempre a la vista, facilitando la métrica de **Reporting Rate**.
- **Simulaciones en Tiempo Real:** Las simulaciones se distribuyen de forma aleatoria durante el mes, evitando el "efecto oficina" (donde un empleado avisa a todos los demás que llegó el correo de prueba).

3. Métricas y Analítica de Datos

Hoxhunt mide el éxito a través de un **Dashboard de Resiliencia**:

- **Success Rate:** Usuarios que reportaron la simulación.
- **Miss Rate:** Usuarios que ignoraron el correo.
- **Fail Rate:** Usuarios que hicieron clic en el enlace malicioso.
- **Engagement Score:** Nivel de participación activa de los departamentos en el entrenamiento.

4. Enfoque Ético y Privacidad

Cumple estrictamente con el **GDPR (Reglamento General de Protección de Datos)**. Su diseño es **no punitivo**: los fallos son anónimos para los gerentes en los reportes individuales iniciales, enfocándose en tendencias grupales para evitar el estrés laboral y la victimización del empleado.

Enlaces y Referencias:

- **Sitio Web:** https://www.hoxhunt.com/
- **Base de Conocimiento:** https://kb.hoxhunt.com/ (Aquí puedes ver tutoriales técnicos reales).
- **Referencia Bibliográfica:**

Hoxhunt. (2024). *The Human Risk Management Platform: Technical Overview*. Recuperado de https://www.hoxhunt.com/platform

Ficha Técnica: Proofpoint (Security Awareness Training)

1. Descripción General y Filosofía

A diferencia de otras plataformas, Proofpoint integra la educación del usuario con su ecosistema de seguridad de correo real. Su filosofía se basa en el concepto de **"Seguridad Centrada en las Personas"**. No tratan a todos los usuarios por igual, sino que priorizan el entrenamiento para aquellos que realmente están recibiendo ataques dirigidos en sus bandejas de entrada.

2. Capacidades Técnicas y Diferenciadores

- **Identificación de VAPs (Very Attacked People):** Este es su mayor diferenciador técnico. Proofpoint analiza quiénes son los usuarios más atacados de la empresa y genera campañas de simulación específicas para ellos, basándose en las amenazas reales (malware, phishing, robo de credenciales) que sus firewalls ya detuvieron.
- **Attack Simulation and Training (AST):** Permite lanzar simulaciones basadas en plantillas que se actualizan diariamente con "señuelos" recolectados de ataques reales capturados a nivel global por su red de inteligencia.
- **Integración con CASB y DLP:** Se conecta con sistemas de prevención de pérdida de datos (DLP) y agentes de seguridad de acceso a la nube (CASB), lo que permite saber si un usuario que falló en un test también está teniendo comportamientos de riesgo en aplicaciones como OneDrive o Slack.

3. Métricas y Analítica de Datos

Proofpoint utiliza el **CISO Dashboard**, que ofrece:

- **Vulnerability Score:** Un puntaje de vulnerabilidad que combina el desempeño en las simulaciones con los ataques reales recibidos.
- **Comparativa Industrial:** Permite ver cómo se desempeña tu organización (o tu grupo de usuarios) frente al promedio de otras empresas del mismo sector (ej. IT, Finanzas, Educación).
- **Métricas de Retención:** Evalúa cuánto tiempo pasa antes de que un usuario olvide lo aprendido y vuelva a cometer un error.

4. Enfoque Ético y Privacidad

Proofpoint se enfoca en la **transparencia**. Sus módulos de entrenamiento incluyen advertencias claras sobre la recolección de métricas. Su enfoque ético se centra en la **protección preventiva**: al identificar a los VAPs, la empresa puede aplicar políticas de seguridad más estrictas (como autenticación multifactor obligatoria) solo para esos usuarios, protegiéndolos sin afectar la productividad de los demás.

Enlaces y Referencias:

- **Sitio Web:** https://www.proofpoint.com/us/products/security-awareness-training
- **Recursos Técnicos:** https://www.proofpoint.com/us/resources/threat-reports (Aquí puedes encontrar reportes de amenazas reales para citar).
- **Referencia Bibliográfica:**

Proofpoint. (2024). *The 2024 State of the Phish Report*. Recuperado de https://www.proofpoint.com/us/resources/threat-reports/state-of-the-phish

Ficha Técnica: KnowBe4 (Human Risk Management Platform)

1. Descripción General y Filosofía

KnowBe4 se centra en reducir la probabilidad de que los usuarios caigan en trampas de ingeniería social mediante el entrenamiento constante y la medición del **Phish-prone™ Percentage** (el porcentaje de usuarios propensos a caer en phishing). Su enfoque principal es el **"Human Risk Management" (HRM)**, que va más allá de un simple video educativo para intentar cambiar la cultura de seguridad de toda la organización.

2. Capacidades Técnicas y Diferenciadores

- **AIDA (Artificial Intelligence Driven Agent):** Utiliza IA para automatizar la selección de plantillas de phishing según el historial del usuario, haciendo que el ataque simulado sea más difícil a medida que el usuario progresa.
- **PhishER Plus:** Una plataforma SOAR ligera que analiza y prioriza automáticamente los correos reportados por los usuarios, permitiendo identificar amenazas reales rápidamente y transformarlas en nuevas oportunidades de entrenamiento.
- **RanSim y USB Security Test:** KnowBe4 no solo prueba correos; permite simular ataques de ransomware inofensivos para verificar las defensas de la red y realizar pruebas con unidades USB dejadas en "lugares estratégicos" para medir la curiosidad de los empleados.
- **Quishing Security Test:** Herramienta específica para simular ataques mediante códigos QR fraudulentos, un vector que ha crecido significativamente en 2026.

3. Métricas y Analítica de Datos

KnowBe4 ofrece uno de los tableros de reportes más detallados del mercado:

- **Personal Risk Score:** Un puntaje individual del 1 al 100 que evalúa la vulnerabilidad de cada usuario basándose en su puesto, clics en simulaciones y cursos completados.
- **Phish-prone™ Percentage:** Muestra la mejora del grupo a lo largo del tiempo (normalmente baja de un 30% a menos de un 5% tras un año de entrenamiento).
- **Security Culture Survey (SCS):** Un instrumento de investigación científica para medir siete dimensiones de la cultura de seguridad, como las actitudes, normas y responsabilidades de los empleados.

4. Enfoque Ético y Privacidad

KnowBe4 cumple con normativas globales como **GDPR**, **FedRAMP Moderate** y **SOC 2 Type II**. Su enfoque ético se basa en la **educación positiva**: el objetivo no es "atrapar" al usuario para castigarlo, sino proporcionarle un **"Teachable Moment"** inmediato mediante páginas de aterrizaje que explican las señales de peligro que omitió.

Enlaces y Referencias:

- **Sitio Web:** https://www.knowbe4.com/
- **Base de Conocimiento Técnica:** https://support.knowbe4.com/
- **Referencia Bibliográfica:**

KnowBe4. (2026). *Beyond Security Awareness Training: Human Risk Management Platform*. Recuperado de https://www.knowbe4.com/

Ficha Técnica: Cofense (Phishing Detection and Response)

1. Descripción General y Filosofía

Cofense (anteriormente conocida como PhishMe) basa su estrategia en la premisa de que **"la tecnología falla, pero las personas pueden detectar lo que las máquinas omiten"**. Su filosofía se centra en la detección basada en humanos, transformando a cada empleado en un sensor de seguridad activo que alimenta directamente al Centro de Operaciones de Seguridad (SOC).

2. Capacidades Técnicas y Diferenciadores

- **Cofense Reporter:** Un botón de reporte intuitivo que permite a los usuarios notificar correos sospechosos con un solo clic, enviando automáticamente las cabeceras técnicas del correo al equipo de seguridad para su análisis.
- **Cofense Triage:** Es su motor de análisis que procesa los correos reportados por los usuarios en tiempo real, utilizando algoritmos para separar las simulaciones de las amenazas reales y priorizar las más peligrosas.
- **Cofense Vision:** Una herramienta de cuarentena que permite a los administradores de IT buscar y eliminar correos maliciosos de todas las bandejas de entrada de la organización de forma simultánea una vez que se ha identificado una amenaza.
- **Inteligencia de Amenazas Compartida:** La plataforma utiliza datos de millones de usuarios a nivel mundial para identificar patrones de ataques de phishing activos antes de que lleguen a tu red.

3. Métricas y Analítica de Datos

Cofense se aleja de las métricas de vanidad y se enfoca en la capacidad de respuesta:

- **Mean Time to Report (MTTR):** Mide el tiempo promedio que tarda un usuario en reportar un correo sospechoso desde que llega a su bandeja.
- **Reporter Accuracy:** Evalúa la calidad de los reportes del usuario, distinguiendo entre correos legítimos reportados por error y amenazas reales detectadas.
- **Incident Response Impact:** Muestra cómo el reporte de un solo usuario ayudó a mitigar un ataque a nivel organizacional.

4. Enfoque Ético y Privacidad

Su enfoque es altamente **colaborativo y transparente**. En lugar de centrarse en quién "cayó" en la trampa, Cofense celebra al usuario que reportó la amenaza. Esto fomenta una cultura de confianza y responsabilidad compartida en lugar de una atmósfera de vigilancia punitiva.

Enlaces y Referencias:

- **Sitio Web:** https://cofense.com/
- **Recursos de Investigación:** https://cofense.com/knowledge-center/
- **Referencia Bibliográfica:**

Cofense. (2026). *Phishing Detection and Response (PDR) Solutions*. Recuperado de https://cofense.com/

Ficha Técnica: Phished (AI-Driven Behavioral Change)

1. Descripción General y Filosofía

Phished se posiciona como una solución de **"piloto automático"** para la concienciación en ciberseguridad. Su filosofía es que el equipo de IT no debería gastar horas diseñando campañas; en su lugar, la IA debe encargarse de enviar el contenido correcto a la persona adecuada en el momento preciso. Se centra en el **cambio de comportamiento holístico** a través de simulaciones personalizadas y micro-aprendizaje.

2. Capacidades Técnicas y Diferenciadores

- **Algoritmo de Autoaprendizaje:** La IA de Phished analiza el nivel de conocimiento y el comportamiento de cada usuario de forma individual. Si un usuario detecta un ataque, el siguiente será más difícil; si falla, recibirá contenido de refuerzo inmediato.
- **Phished Academy:** Una plataforma de aprendizaje integrada que ofrece módulos cortos y dinámicos basados en los errores cometidos por el usuario durante las simulaciones.
- **Simulaciones Multicanal:** A diferencia de otras herramientas, Phished puede simular ataques de **Phishing (correo)**, **Smishing (SMS)** y **Vishing (voz)**, además de alertas de seguridad fraudulentas en el navegador.
- **Threat Intelligence Integration:** La plataforma se alimenta de bases de datos de amenazas globales para replicar ataques que están ocurriendo en el "mundo real" en ese mismo instante.

3. Métricas y Analítica de Datos

Phished ofrece un **Behavioral Index (Índice de Comportamiento)** que se aleja de los gráficos estáticos:

- **Individual Progress Tracking:** Muestra la evolución de cada empleado desde su primer día en la plataforma.
- **Risk Reduction Score:** Una métrica que calcula cuánto ha disminuido la probabilidad de una brecha real gracias al entrenamiento.

- **Automated Reporting:** Genera informes ejecutivos listos para presentar a la gerencia sin intervención humana.

4. Enfoque Ético y Privacidad

Al ser una empresa europea, Phished tiene un enfoque **"Privacy by Design"** cumpliendo estrictamente con el **GDPR**. La plataforma asegura que los datos recolectados se usen exclusivamente con fines educativos. Su enfoque es **totalmente positivo**: la IA actúa como un "entrenador personal" de ciberseguridad, no como un supervisor punitivo.

Enlaces y Referencias:

- **Sitio Web:** https://phished.io/
- **Blog de Ciberseguridad:** https://phished.io/blog/ (Ideal para encontrar casos de estudio).
- **Referencia Bibliográfica:**

Phished. (2026). *The Future of Cybersecurity Awareness: AI-Driven Behavioral Change*. Recuperado de https://phished.io/

Ficha Técnica: NINJIO (Cybersecurity Awareness Training)

1. Descripción General y Filosofía

La filosofía de NINJIO es: **"Si no puedes captar su atención, no puedes enseñarles"**. En lugar de aburridas diapositivas de PowerPoint, utilizan el **Storytelling** y la **Psicología del Comportamiento**. Su contenido estrella son episodios de video de 3 a 4 minutos inspirados en brechas de seguridad reales que ocurrieron recientemente en empresas conocidas.

2. Capacidades Técnicas y Diferenciadores

- **Producción Estilo Anime:** Los episodios están guionados por escritores de Hollywood y animados profesionalmente. Esto genera una conexión emocional que mejora la retención del conocimiento.
- **NINJIO PHISH:** Una herramienta de simulación de phishing que permite enviar correos basados en los mismos temas tratados en los episodios de video, cerrando el círculo entre teoría y práctica.
- **Episodios Basados en la Actualidad:** Lanzan un nuevo episodio cada mes basado en un ataque real reportado en las noticias, lo que mantiene el contenido relevante y "fresco".
- **NINJIO HR:** Una división específica que utiliza estos mismos métodos para enseñar sobre acoso laboral, ética y cumplimiento, mostrando la versatilidad de su método educativo.

3. Métricas y Analítica de Datos

NINJIO utiliza un sistema de medición basado en el compromiso del usuario:

- **NINJIO Risk Algorithm:** Calcula el riesgo de la organización basándose en la rapidez con la que los usuarios ven los episodios y su desempeño en los cuestionarios posteriores.

- **Gamificación (Leaderboards):** Permite crear competencias entre departamentos para ver quién tiene la mejor "higiene digital", otorgando medallas y reconocimientos.
- **Reportes de Cumplimiento:** Genera datos listos para auditorías de normativas como SOC2, HIPAA y PCI DSS.

4. Enfoque Ético y Privacidad

Su enfoque es **totalmente positivo y no punitivo**. NINJIO cree que el miedo no es un buen maestro. Por ello, sus videos suelen tener un toque de humor y empatía, mostrando a las víctimas de los ataques no como "tontos", sino como personas que fueron manipuladas profesionalmente, lo que reduce el estigma de reportar errores.

Enlaces y Referencias:

- **Sitio Web:** https://ninjio.com/
- **Canal de YouTube (Muestras):** https://www.youtube.com/@NINJIO (Aquí puedes ver trailers de sus episodios para tu investigación).
- **Referencia Bibliográfica:**

NINJIO. (2026). *Cybersecurity Awareness Training: The Power of Storytelling*. Recuperado de https://ninjio.com/

Ficha Técnica: Mimecast (Awareness Training)

1. Descripción General y Filosofía

La filosofía de Mimecast es la **"Seguridad Integrada"**. A diferencia de otras herramientas que se compran por separado, Mimecast integra la concienciación dentro de su Gateway de seguridad. Su enfoque se basa en que la educación debe ser persistente, breve y, sobre todo, basada en datos reales de los ataques que su propio sistema bloquea cada segundo.

2. Capacidades Técnicas y Diferenciadores

- **Safe Phish:** Esta funcionalidad permite convertir correos de phishing reales que han sido neutralizados por Mimecast en simulaciones de entrenamiento seguras para los usuarios.
- **Integración con el Gateway:** Al ser un filtro de correo (Email Security Gateway), Mimecast sabe exactamente qué usuarios están siendo atacados por campañas reales y les asigna entrenamiento preventivo de forma automática.
- **Módulos de Video de Comedia:** Utilizan un enfoque de "humor serio". Sus videos suelen durar menos de 2 minutos y presentan a personajes recurrentes en situaciones cómicas de oficina para maximizar el compromiso.
- **Protección de URL y Adjuntos:** Si un usuario hace clic en un enlace real que el sistema aún está analizando, Mimecast muestra una pantalla intermedia de advertencia que sirve como micro-entrenamiento en el momento justo del riesgo.

3. Métricas y Analítica de Datos

Mimecast ofrece una visión de 360 grados del riesgo:

- **SAFE Score (Security Assessment for Everyone):** Un índice que califica el riesgo de la organización comparándolo con otras empresas del mismo sector y tamaño.
- **Métricas de Intento de Clic:** No solo mide quién "cayó", sino cuántas veces un usuario intentó acceder a un sitio bloqueado antes de desistir.
- **Dashboard de Higiene Digital:** Analiza comportamientos de riesgo fuera del correo, como el uso de contraseñas débiles o la navegación en sitios no productivos.

4. Enfoque Ético y Privacidad

Mimecast se centra en la **protección del empleado**. Su enfoque ético es defensivo: utiliza la simulación para fortalecer el "escudo" humano sin invadir la privacidad personal. Todos los datos están cifrados y cumplen con estándares internacionales de cumplimiento como ISO 27001 y HIPAA.

Enlaces y Referencias:

- **Sitio Web:** https://www.mimecast.com/
- **Centro de Recursos:** https://www.mimecast.com/resources/
- **Referencia Bibliográfica:**

Mimecast. (2026). *The State of Email Security 2026 Report*. Recuperado de https://www.mimecast.com/

Ficha Técnica: Infosec IQ (Security Awareness Training)

1. Descripción General y Filosofía

La filosofía de Infosec IQ se resume en **"Ciberseguridad para todos"**. A diferencia de otras plataformas, su enfoque es puramente educativo y técnico, basado en el **marco de trabajo de NIST (National Institute of Standards and Technology)**. Su objetivo es empoderar a los usuarios mediante el conocimiento, transformándolos de ser el "eslabón más débil" a ser una línea de defensa activa y consciente.

2. Capacidades Técnicas y Diferenciadores

- **Alineación con el NIST:** Todos sus módulos de entrenamiento están mapeados directamente con las directrices del NIST, asegurando que el contenido sea académicamente sólido y cumpla con estándares globales.
- **Infosec Skills:** Se integra con una plataforma de aprendizaje profundo donde los usuarios de IT (como tú) pueden tomar cursos avanzados de penetración, análisis de malware y respuesta a incidentes.
- **Simulador de Phishing Automatizado:** Permite programar campañas que se disparan automáticamente cuando un usuario muestra un comportamiento de riesgo en la red.

- **Contenido Localizado:** Ofrece entrenamiento en más de 34 idiomas con contextos culturales específicos, lo que es ideal para empresas multinacionales.

3. Métricas y Analítica de Datos

Infosec IQ utiliza un sistema de reporte muy detallado enfocado en el cumplimiento:

- **IQ Score:** Una métrica que califica el conocimiento de ciberseguridad del usuario basada en exámenes y resultados de simulaciones.
- **PhishSim Dashboard:** Muestra en tiempo real cuántos usuarios abrieron el correo, hicieron clic o enviaron sus credenciales en la página falsa.
- **Mapas de Habilidades:** Identifica qué departamentos o grupos necesitan refuerzo en temas específicos como "Uso de contraseñas" o "Seguridad en redes sociales".

4. Enfoque Ético y Privacidad

Infosec IQ promueve una **Cultura de Ciberseguridad Positiva**. Su enfoque ético se basa en la **educación basada en roles**: no se le enseña lo mismo a un contador que a un desarrollador, respetando el tiempo del usuario y proporcionando solo la información que realmente necesita para estar seguro en su puesto de trabajo.

Enlaces y Referencias:

- **Sitio Web:** https://www.infosecinstitute.com/iq/
- **Centro de Recursos:** https://www.infosecinstitute.com/resources/
- **Referencia Bibliográfica:**

Infosec Institute. (2026). *Security Awareness Training and Phishing Simulations: Infosec IQ Technical Overview*. Recuperado de https://www.infosecinstitute.com/

5. Tabla Técnica Comparativa de Plataformas

Esta tabla presenta los criterios de análisis, capacidades técnicas y el enfoque ético de las 8 soluciones líderes del mercado.

Plataforma	Factor Diferenciador	Métricas Clave	Integración Técnica	Enfoque Ético	Limitaciones Técnicas	Cumplimiento (Compliance)
1. **Hoxhunt**	Gamificación extrema y recompensas.	Tasa de reporte y éxito.	Add-in nativo en Outlook/Gmail.	Refuerzo positivo y no punitivo.	Dependencia total de la IA; si el add-in falla, se pierde la métrica de reporte.	GDPR (Privacidad por diseño).
2. **Proofpoint**	Enfoque en VAPs (Personas Muy Atacadas).	Vulnerability Score integrado.	Ecosistema cerrado de seguridad de correo.	Protección preventiva y transparencia.	Costo de implementación elevado; requiere infraestructura robusta.	NIST, FISMA, GDPR.
3. **KnowBe4**	Biblioteca masiva y AIDA.	Phish-prone % y Risk Score.	Alta integración (AD, Azure, APIs).	Teachable Moments y educación.	La curva de aprendizaje para administradores puede ser compleja.	GDPR, SOC2, HIPAA, PCI DSS.

Plataforma	Factor Diferenciador	Métricas Clave	Integración Técnica	Enfoque Ético	Limitaciones Técnicas	Cumplimiento (Compliance)
4. **Cofense**	Inteligencia colectiva (Botón de reporte).	Mean Time to Report (MTTR).	Alta (Integración con SOC/SOAR).	Colaboración y reporte activo.	Requiere un equipo de IT/SOC dedicado para analizar reportes.	SOC2 Type II, FedRAMP.
5. **Phished**	IA de autoaprendizaje sin intervención.	Behavioral Index individual.	Automatización vía API y Cloud.	Privacy by Design (GDPR).	Menos flexibilidad para el diseño manual de campañas específicas.	GDPR, ISO 27001.
6. **NINJIO**	Storytelling de Hollywood (Anime).	Engagement y retención emocional.	Portal LMS o integración con SCORM.	Empatía y reducción de estigma.	El contenido en video puede demandar alto ancho de banda en redes lentas.	HIPAA, GDPR, NIST.
7. **Mimecast**	Integración nativa con el Gateway.	SAFE Score (vs. Industria).	Seguridad Híbrida (Inline Gateway).	Protección defensiva del usuario.	Muy difícil de implementar si no se usa su gateway de correo principal.	ISO 27001, HIPAA, SOC2.

Plataforma	Factor Diferenciador	Métricas Clave	Integración Técnica	Enfoque Ético	Limitaciones Técnicas	Cumplimiento (Compliance)
8. **Infosec IQ**	Alineación estricta con el NIST.	IQ Score y mapas de habilidades.	Plataforma SaaS con módulos interactivos.	Cultura de seguridad positiva.	Interfaz de administración menos intuitiva comparada con competidores.	NIST (Mapeo total), GDPR.

6. Conclusión

Tras el análisis exhaustivo de las ocho plataformas líderes en el mercado, se concluye que la gestión del riesgo humano ha evolucionado de un entrenamiento estático a una **arquitectura de defensa conductual basada en datos**. La investigación demuestra que la efectividad de una campaña de ingeniería social no reside únicamente en la sofisticación de los señuelos, sino en la **capacidad de integración técnica y la personalización de la respuesta** ante el comportamiento del usuario.

Mientras que soluciones como **KnowBe4** y **Proofpoint** destacan por su robustez analítica y la generación de un "Risk Score" basado en telemetría histórica, herramientas como **Hoxhunt** y **Phished** señalan que el futuro de la seguridad corporativa depende de la **automatización mediante Inteligencia Artificial adaptativa**. Un hallazgo crítico es que la métrica más valiosa para una organización no es la tasa de clics, sino el **Reporting Rate** (Tasa de Reporte); fomentar que el usuario actúe como un sensor activo reduce drásticamente el tiempo de detección de amenazas reales.

Finalmente, el análisis confirma que un **diseño ético y no punitivo** es el estándar de la industria para garantizar la resiliencia organizacional. La implementación de conceptos como el **"Teachable Moment"** asegura que la corrección ocurra en el punto de falla, optimizando la retención del conocimiento sin comprometer la moral del personal. Estos principios técnicos y éticos fundamentarán el desarrollo del **Phishing Quiz**, transformando la simulación en un activo de aprendizaje que fortalece la postura de seguridad frente a las amenazas de ingeniería social en 2026.

Aquí tienes la lista de referencias bibliográficas completa, organizada en orden alfabético y bajo las normas **APA 7**, que sustenta toda la investigación técnica y comparativa de las plataformas analizadas en tu proyecto:

7. Referencias

- **Cofense.** (2026). *Phishing Detection and Response (PDR) Solutions: Technical Overview and Collective Intelligence*. Recuperado de https://cofense.com/
- **Hoxhunt.** (2024). *The Science of Behavior Change in Cybersecurity: Human Risk Management and Adaptive AI*. Recuperado de https://www.hoxhunt.com/
- **Infosec Institute.** (2026). *Security Awareness Training and Phishing Simulations: Infosec IQ NIST Mapping and Role-Based Training*. Recuperado de https://www.infosecinstitute.com/iq/
- **KnowBe4.** (2026). *2026 Phishing by Industry Benchmarking Report: Measuring the Phish-prone™ Percentage*. Recuperado de https://www.knowbe4.com/
- **Mimecast.** (2026). *The State of Email Security 2026: Awareness Training Integration and SAFE Score Metrics*. Recuperado de https://www.mimecast.com/
- **National Institute of Standards and Technology (NIST).** (2022). *Introduction to Cybersecurity for Human Resources (NIST SP 800-50)*. U.S. Department of Commerce.

- **NINJIO.** (2026). *Cybersecurity Awareness Training: The Power of Narrative Storytelling and Emotional Engagement*. Recuperado de https://ninjio.com/
- **Phished.** (2026). *AI-Driven Behavioral Change and Automated Phishing Simulations for Organizations*. Recuperado de https://phished.io/
- **Proofpoint.** (2024). *State of the Phish 2024: Identifying and Protecting Very Attacked People (VAPs)*. Recuperado de https://www.proofpoint.com/